

Reporting & Professional Communication

The audience split

- Executives** care about business risk: "what does this mean for us, in numbers/money?"
- Engineering** cares about reproducible fixes: "which file, which line, which config?"
- Compliance** cares about evidence: scan dates, scope, remediation status

A good report serves all three in sections.

Finding anatomy

Field	Example
Title	"SQL injection in product search"
Severity	High (CVSS 8.6 vector AV:N/AC:L/...)
Asset/endpoint	https://app.example.com/api/products?q=
Description	The q parameter built into SQL unsafely
Vulnerability detail	Parameterized query missing; stacked queries possible
Reproduction	exact curl + request/response (redacted PII)
Impact	Full DB read incl. customer PII; potential RCE via stacked + INTO OUTFILE
Recommendation	Use parameterized queries; add WAF rule while fixing
Reference	CWE-89, OWASP A03

Severity calibration

Critical: unauthenticated RCE, default-credential access to admin

High: authenticated RCE, SQLi on sensitive data

Medium: XSS limited scope, misconfigurations you can exploit

Low: info disclosure, hygiene

Never inflate: credibility dies with exaggeration. CVSS vector provides the objective numeric anchor.

Essentials to include

Executive summary (top findings, risk statement)

Methodology (tests run, what was covered and NOT)

Scope + RoE reference

Findings with the anatomy above

Remediation prioritized (p0 now, p30 days, etc.)

Appendix: detailed repro, tool versions, evidence hashes

The report is the product. Exploits are the means. If your report is readable and actionable, you are worth every dollar. Trim fluff; keep proof.

[← Scanning, Exploitation & Pos...](#)

[Legal Boundaries & Engagement ...](#)